SECURITY AWARENESS & DEFENSE PROGRAM

Phishing Awareness Training

Practical skills to recognize deceptive emails, fake websites, and social engineering traps before they strike.

Presenter: [Muhammad Basim Zia, Security Trainer] **Date:** October 2026 **Audience:** All Staff & Students

THE THREAT LANDSCAPE

Why Phishing Matters

Attackers target people because human trust bypasses technical firewalls.

62%

Human Element in Breaches
Verizon DBIR 2026 Report

$4.8M

Average Phishing Breach Cost
IBM Cost of a Data Breach

1.07M

Quarterly Phishing Attacks
APWG Trends Report Q2 2026

$3.05B

Annual BEC Wire Fraud Losses
FBI IC3 Internet Crime Report

Simulation Click Rates Rise When Attackers Leave Email (Verizon DBIR 2026)



FUNDAMENTALS

What Is Phishing?

Definition: Phishing is a cyberattack where criminals impersonate trusted organizations via email, text, or phone to trick people into revealing passwords, data, or money.



1. The Bait

Fake message arrives looking like a trusted sender



2. The Hook

Urgency or fear pressures a fast reaction



3. The Action

Target clicks fake link or enters login password



4. The Damage

Criminals steal accounts, funds, or network access

ATTACK GLOSSARY

8 Common Types of Phishing

Attack Type	Channel	Primary Target	How the Trick Works
Email Phishing	Bulk Email	General public	Mass message with fake password reset link
Spear Phishing	Targeted Email	Specific individual	Uses victim's real name, job title, or project
Whaling	Executive Email	CEOs & leaders	Fake subpoena, board notice, or tax audit
Smishing	SMS Text	Mobile users	Fake package delivery fee or bank fraud text
Vishing	Voice Call	Helpdesk & staff	Caller pretends to be IT support or bank agent
Quishing	QR Code	Phone camera	Malicious QR code in PDF, poster, or mail
Clone Phishing	Copied Email	Past recipients	Duplicates real email but swaps link for trap
BEC (Wire Fraud)	Business Email	Finance & HR	Impersonates vendor or executive to steal funds

PSYCHOLOGICAL TRIGGERS

6 Social Engineering Tactics

Social Engineering: Manipulating natural human emotions to bypass logical caution.

1. Urgency

"Your account expires in 15 minutes."

2. Fear

"Suspicious payroll change detected—cancel now."

3. Authority

"CEO request: Wire vendor deposit before noon."

4. Curiosity

"Confidential Q4 departmental restructuring list.xlsx"

5. Greed

"Claim your $250 employee wellness gift card."

6. Familiarity

"Great seeing you—check the photos from lunch!"

INBOX INSPECTION

How to Recognize Phishing Emails

`[1] From: IT Security Desk`

`[2] Subject: URGENT: Password Expiring in 2 Hours!!`

---

[3] Dear Valued Employee,

We detected unauthorized sign-in attempt. **[4] Kindly verify your account needful immediately** or email access will be terminated permanently.

`[5] Link: Verify Portal (Hovers to: http://auth-reset.bad-example.net/login)`

`[6] Attachment: Security_Certificate_Update.exe (1.4 MB)`

⚠ **1. Spoofed Sender:** Uses fake domain `alert-login-example.com`

⚠ **2. Urgent Tone:** Creates panic with a 2–hour cutoff threat

⚠ **3. Generic Greeting:** Says "Valued Employee" instead of your name

⚠ **4. Grammar Errors:** Awkward phrasing and unusual punctuation

⚠ **5. Mismatched Link:** Hover preview points to `bad-example.net`

⚠ **6. Risky Attachment:** Executable `.exe` file installs malware

URL & BROWSER SAFETY

How to Recognize Fake Websites

Typosquatting & Look-Alikes

Registering misspelled domains (`examp1e.com` or `exarnple.com`).

Misleading Subdomains

Read right-to-left before the first single slash **/** to find the real owner.

The HTTPS Padlock Myth

A padlock only means data is encrypted in transit—over 80% of phishing sites use HTTPS.

Real vs. Fake URL Inspector

- ✅ `https://login.example.com/account`
- ⚠️ `https://login.examp1e.com/account`
- ⚠️ `https://example.com.verify-id.net/login`
- ⚠️ `https://exarnple.com/portal`
- ⚠️ `https://secure-example-support.com`

MOBILE & VOICE THREATS

Spotting Smishing and Vishing

Smishing (SMS Phishing)

```
[Sender: +1-555-0144] ALERT: Package #882 held due to invalid zip code. Pay $1.50 fee at http://pkg-redeliver-example.com
```

- **Unknown Numbers:** Texts from random mobile numbers
- **Fee Traps:** $1–$2 fees designed to steal card numbers
- **Safe Action:** Check tracking directly on the courier app

Vishing (Voice Phishing)

```
"Hi, this is Alex from Corporate IT (555-0199). To block a hacker on your account, read me the 6-digit code just sent to your phone."
```

- **Spoofed Caller ID:** Displayed names and numbers are easily faked
- **MFA Code Theft:** Real IT staff never ask for login codes
- **Safe Action:** Hang up and call the official internal directory

REAL-WORLD CASE STUDY 1 (2013)

The 2013 Target Vendor Breach

40M

Payment Cards Compromised

Plus personal records for up to 70M shoppers and $162M+ in breach costs

What Happened: Attackers breached third-party HVAC contractor Fazio Mechanical Services two months before Thanksgiving 2013.

Tactic Used: Phishing email infected the vendor with Citadel password-stealing malware to capture Target portal logins.

The Impact: Attackers moved from the vendor portal to checkout registers, scraping 40 million cards during holiday shopping.

The Lesson: Supply chains are only as strong as the most phishable partner—always enforce Multi-Factor Authentication.

REAL-WORLD CASE STUDY 2 (2013–2015)

Google & Facebook Invoice Scam

What Happened: Fraudster Evaldas Rimasauskas registered a shell company matching real hardware vendor Quanta Computer.

Tactic Used: Business Email Compromise (BEC)—targeted phishing emails with forged invoices, contracts, and bank instructions.

The Impact: Employees wired roughly $99M from Facebook and $23M from Google before detection and prosecution.

The Lesson: Never rely on email alone to approve banking changes—verify out-of-band via a known phone number.

$120M+

Wired via Forged Invoices

Zero malware used—purely spoofed vendor emails and routine invoice approval fatigue

REAL-WORLD CASE STUDY 3 (2020)

2020 Twitter Phone Spear-Phishing Hack

In July 2020, callers impersonating IT support tricked staff into entering credentials on a fake VPN portal.

What Happened

Coordinated vishing calls targeted remote staff.

Tactic Used

Phone spear-phishing captured VPN credentials.

The Impact

130 high-profile accounts hijacked via admin tools.

The Lesson

Verify IT requests through official internal channels.

DEFENSIVE ROUTINE

The 5-Step Habit: STOP, LOOK, THINK, VERIFY, REPORT

A 5-second pause neutralizes almost every social engineering tactic.



1. STOP

Pause whenever a message demands instant action



2. LOOK

Inspect full sender address and hover over links



3. THINK

Ask if this sender would normally request passwords



4. VERIFY

Confirm via a trusted second channel or phone number



5. REPORT

Click Report Phishing so IT blocks the campaign

SAFEGUARD YOUR ACCOUNTS

6 Best Practices to Avoid Falling Victim

Enable MFA Everywhere

Multi-Factor Authentication (MFA) adds a second verification step.

Use a Password Manager

Password managers never auto-fill logins on fake look-alike URLs.

Hover Before Clicking

Rest your cursor over any link to preview the true web address.

Second-Channel Check

Verify wire transfers or sensitive requests via a known phone number.

Keep Software Updated

Install browser and OS updates promptly to block malware exploits.

Never Share OTPs

One-Time Passcodes (OTPs) are for your screen only—never read them aloud.

RAPID INCIDENT RESPONSE

What to Do If You Clicked



Zero Blame, Fast Action

Reporting within 5 minutes turns a potential breach into a blocked attempt.

1. **Disconnect Immediately:** Turn off Wi-Fi or unplug Ethernet if a file downloaded.
2. **Change Your Password:** Reset credentials immediately using a separate clean device.
3. **Revoke Active Sessions:** Sign out of all logged-in devices and check MFA settings.
4. **Report to IT Security:** Click the Report Phishing button or call `555-0199`.
5. **Share Exact Details:** Tell IT whether you clicked a link, opened a file, or typed a password.

ENGAGEMENT CHECK

Interactive Quiz: Test Your Instincts (8 Questions)

#	Scenario or Question	Your Challenge
Q1	Email from `payroll@examp1e.com` asks you to confirm your W-2 tax form.	**Phishing or Legit?**
Q2	A login page at `https://login-example.net` displays a valid HTTPS padlock icon.	**Safe to log in? (A: Yes / B: No)**
Q3	"I am in a board meeting—buy five $100 gift cards now. — CEO"	**Tactic? (A: Greed / B: Authority + Urgency)**
Q4	Caller from "Helpdesk" asks you to read the 6-digit OTP code sent to your phone.	**Phishing or Legit?**
Q5	A sticker placed over a public parking meter directs you to scan a QR code to pay.	**Name this phishing type**
Q6	A trusted supplier emails a PDF requesting an immediate change to their bank account.	**Next step? (A: Reply / B: Call known number)**
Q7	"Dear Customer, click `http://198.51.100.7/example` to unlock your account!"	**Spot 2 red flags**
Q8	You just typed your work password into a suspicious page before noticing the URL.	**First step? (A: Wait / B: Reset & Report)**

QUIZ DEBRIEF & EXPLANATIONS

Interactive Quiz: Answer Key

Q1: Phishing. Uses typosquatting (`examp1e.com` replaces "l" with "1").

Q2: B (No). Padlock only means encrypted traffic, not a legitimate domain.

Q3: B (Authority + Urgency). Classic executive gift-card impersonation.

Q4: Phishing (Vishing). Real IT staff never ask for MFA or OTP codes.

Q5: Quishing. QR-code phishing hides malicious links behind camera scans.

Q6: B (Call known number). Always verify payment changes out-of-band.

Q7: Generic greeting & raw IP URL. Trusted brands don't use raw IP links.

Q8: B (Reset & Report). Fast password reset and IT alert stops account takeover.

HANDS-ON DRILL & SUMMARY

Mini-Activity, Key Takeaways & Resources

Live Activity: Hover & Verify

Link A: https://portal.example.com/login

`Hover URL: https://portal.example.com.auth-check.net ⚠ TRAP`

Link B: View Q4 Benefits Guide

`Hover URL: https://hr.example.com/benefits-2026 ✓ SAFE`

Link C: Reset Corporate Password

`Hover URL: http://support-exarnple.com/reset ⚠ TRAP ("rn")`

4 Key Takeaways

- **Pause at Urgency:** Emotion is your cue to slow down.
- **Verify Out-of-Band:** Call known numbers for wire or IT requests.
- **Use MFA & Managers:** Stop fake sites from stealing logins.
- **Report Immediately:** Fast reporting protects everyone.

Resources & References

- **APWG:** Anti-Phishing Working Group (apwg.org)
- **CISA:** Cybersecurity & Infrastructure Security Agency (cisa.gov)
- **Practice:** Google Phishing Quiz & Phishing.org



STAY VIGILANT • STOP, LOOK, THINK, VERIFY, REPORT

Thank You & Questions